# 커넥티드카 앱을 통한 차량 권한 탈취 가능성 실증 연구

정 연 수[1)]·조 성 제[*2)]

단국대학교 소프트웨어학과[1)*2)]

# Vehicle Privilege Escalation through Connected Car App: An Empirical Study

Yeonsu Jung[1)]·Seong-je Cho[*2)]

[1)*2)]*Department of Software, Dankook University, 152, Jukjeon-ro, Suji-gu, Yongin-si, Gyeonggi-do 16890, Korea*

**Abstract** : 커넥티드카 생태계에서 공식 차량 앱(Connected Car App, CCA)은 원격 제어와 차량 공유 등 강력한 권한을 제공한다. 본 논문은 2022 Avante CN7과 연동하는 CCA인 안드로이드블루링크 앱을 대상으로 정적·동적 역공학을 수행하여, 차량에 대한 물리적 접근 없이 CCA 내부 데이터 유출만으로 차량 권한 탈취가 가능함을 실증하였다.

**Key words** : Connected Car(커넥티드카), Connected Car App(차량 연동 앱), Bluelink(블루링크), Reversing(역공학)

## 1. 서 론

커넥티드카의 보급은 차량 내부 ECU 간 네트워크뿐만 아니라 차량 외부의 통신 프로토콜, 외부 단말 및 제조사 공식 차량 앱(Connected Car App, 이하 CCA) 등 새로운 공격 표면으로 확장되었다. CCA는 차량 제어·모니터링·공유 기능 등 차량에 대한 강력한 권한을 제공하므로, 적절한 보안 통제가 이뤄지지 않으면 인명 및 재산상의 심각한 피해로 이어질 수 있어, 엄격한 보안 기준의 적용이 필요하다. 기존 연구와 보안 보고서는 확장된 공격 표면에 대한 위협을 꾸준히 다루어 왔으나, OEM이 제공하는 CCA의 취약점이 공격 벡터로 사용되어 차량 권한 탈취로 이어짐을 실증한 연구는 상대적으로 부족하다.

본 논문은 국내 차량 제조사의 CCA를 대상으로 정적·동적 역공학을 수행하여 CCA의 취약점이 어떻게 차량 권한 탈취로 이어질 수 있는지를 실증한다. 본 논문에서 제시된 관련 위협과 취약점은 공식 절차에 따라 책임 있는 담당 기관에 보고되었으며, 보안·윤리적 고려로 인해 PoC의 구체적 구현 내용은 공개하지 않는다.

* 조성제, E-mail: sjcho@dankook.ac.kr

## 2. 배경 및 관련 연구

차량 보안 분야의 공격 표면이 지속적으로 확장되면서, 많은 연구자와 보안 담당자들은 이에 대한 연구를 꾸준히 수행하고 있다. Jin Kim 등은 스마트폰·클라우드·차량 간의 데이터 흐름을 DFD로 모델링하고, STRIDE·LINDDUN 기반 위협 분석을 수행하였다. 이를 국내에서 서비스 중인 임의의 CCA 4개에 적용한 결과, 다수의 취약점을 식별하였다.[1)] 윤지원 등은 자동차 분야의 CVE를 수집·분류하여 국제 표준에 제시된 위협 유형과 연결함으로써 표준 기반 위협 모델과 실제 사례 간의 격차를 보였다.[2)]

차량 보안에 대한 취약점 분석은 2015년 Jeep

Cherokee 리콜 사태[3]에서 주목받았으며, 2024년 KIA의 딜러 계정 접근을 통한 차량 접근 권한 탈취[4]으로 최근까지도 보고가 이어지고 있다. 또한 블루투스 통신을 악용한 PerfektBlue 취약점[5]이 공개되면서, 차량 외부 통신 프로토콜에서도 취약점이 존재할 수 있음을 보였다.

이러한 선행 연구와 취약점 보고 사례들은 CCA 및 연동 인프라가 차량과 긴밀한 주요 정보를 다루기 때문에 보안 강화를 위한 지속적인 노력이 필요함을 보여준다. 본 논문은 이러한 흐름의 연장선에서, 특히 CCA 자체 취약점이 권한 탈취로 직결될 수 있음을 실증한다.

## 3. CCA 분석

### 3.1 분석 대상

국내 CCA 가운데 실제 차량을 대상으로 실험이 가능한 현대자동차의 블루링크 앱을 분석 대상으로 선정하였다. 실험에 사용한 차량과 스마트폰, 앱의 정보가 Table 1에 나타나 있다.

Table 1 분석 대상

| | Name | Version |
|---|---|---|
| Application | Bluelink | 3.922(latest) |
| Mobile Device(pure) | Galaxy S21 | Android 14 |
| Mobile Device(rooting) | Galaxy A23 | Android 14 |
| Car | Avante CN7 | 2022 |

### 3.2 분석 방법

정적-동적 분석을 병행하였으며, 전체 분석 과정은 (1) APK 취득 및 정적 분석, (2) 런타임 무결성 검증 로직 우회, (3) 추가 코드 획득 및 정적 분석, (4) 기능 동작 테스트, (5) 내부 저장소·네트워크 패킷 분석 순으로 진행되었다.

#### 3.2.1 도구

분석에 사용된 주요 도구를 Table 2에 정리하였다.

Table 2 분석 도구

| | Name | Version |
|---|---|---|
| Static | adb | 25.0.2-12147458 |
| | apktool | 2.11.1 |
| | jd-gui | 1.6.6 |
| Dynamic | Frida | 16.6.6 |
| | Python | 3.12.0 |
| | Chrome Devtools | 136.0.7103.114 |

#### 3.2.2 분석 과정

1) APK 취득 및 정적 분석

Google Play에서 배포된 APK 파일을 정적 분석한 결과, 초기 패키지에는 동적 dex 로딩 기법[6]이 적용되어 있었으며 로더와 무결성 검증 관련 모듈이 포함되어 있었다.

2) 런타임 무결성 검증 로직 우회

앱 초기 실행 흐름을 따라가면서 무결성 검증 로직을 추적하였다. 무결성 검증 로직은 특정 내부 객체의 존재 여부에 따라 후속 검증이 비활성화되는 논리적 의존성이 있었다. 해당 취약점을 통해 런타임 우회에는 성공했으나, 앱 기능은 정상적으로 동작하지 않았다.

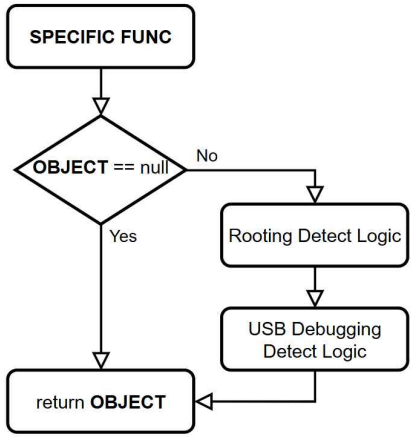


Fig. 1 무결성 검증 로직 순서도

3) 추가 코드 획득 및 정적 분석

추가적인 루팅 탐지 로직이 존재함을 예상하고, 프로세스 로딩 이후 메모리에서 dex 이미지를 덤프하여 추가 코드를 획득하였다. 이를 다시 정적 분석하여 추가로 루팅 탐지 로직을 식별하였다. 런타임에 해당 로직을 우회한 결과, 기능을 정상적으로 사용할 수 있었다.

4) 기능 여부 실험

순정 기기(S21)와 루팅 기기(A23)를 동일 차량 환경에서 동등 조건으로 시험하여, 루팅된 기기에서의 정상 작동 여부를 비교 검증하였다. Table 3을 보면, 서로 다른 환경 간 기능 동작의 차이가 관찰되지 않아, 루팅된 기기에서 CCA를 동작시키는 것이 가능함을 확인하였다.

Table 3 기능 실험 결과

| Category | Target | Feature | S21 (pure) | A23 (rooting) |
|---|---|---|---|---|
| Control | Engine | Start/Stop | X | X |
| | Doors | Lock/Unlock | O | O |
| | Light | ON | O | O |
| Map | | sendToCar | O | O |
| More | | carSharing | O | O |

5) 내부 저장소·네트워크 패킷 분석

애플리케이션 내부 저장소에 암호화된 사용자 데이터가 존재하였다. 해당 데이터는 대칭키 방식으로 암·복호화되지만, 비밀키를 획득할 수 있었으므로 복호화가 가능하였다. 복호화된 데이터에는 인가 토큰과 계정 및 차량 식별자, 기타 설정값이 포함되어 있었다.

또한 네트워크 패킷을 분석하여 주요 API 동작에 필요한 인증 정보와 파라미터를 식별하였다. 제어 기능은 2FA를 통해 획득한 제어 토큰을 사용한 반면, 차량 모니터링과 공유 기능은 추가 인증 필요 없이 기존의 인가 토큰을 이용하였다.

## 4. 공격 시나리오 제안

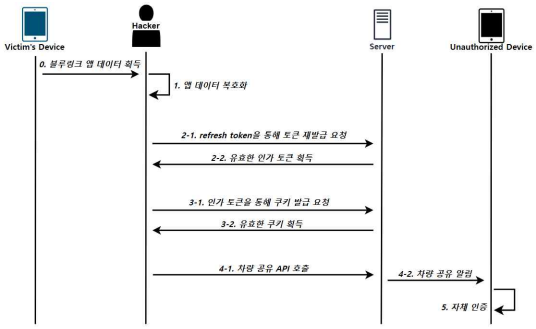


Fig. 2 공격 시나리오 개요

공격자는 희생자 단말의 CCA 내부 저장소에 접근할 수 있음을 가정하고, Fig. 2의 흐름에 따라 차량 제어 권한이 비인가 단말로 강제 공유될 수 있음을 보인다. 구체적인 PoC 코드는 보안·윤리적 이유로 공개하지 않는다.

### 4.1 데이터 복호화

희생자 단말의 CCA 내부 저장소에서 암호화된 사용자 데이터와 비밀키가 존재하며, 공격자는 이를 복호화하여 차량 공유 기능을 수행하는 데 필요한 API 호출에 활용될 수 있다.

### 4.2 비인가 API 악용

블루링크의 차량 공유 기능은 인가 토큰과 쿠키를 기반으로 사용자 인증을 수행한다. 참고로 쿠키 자체는 접근 토큰 기반으로 발급된다.

Fig.2의 두 번째 단계에서는 재발급 토큰을 통해 유효한 인가 토큰을 재발급받을 수 있다. 이는 인가 기법 구현 과정에서 토큰 재사용 방지를 위한 보안 기능이 충분히 적용되지 않았기 때문에 가능하다.

세 번째 단계에서 유효한 인가 토큰을 통해 쿠키를 획득하고 네 번째 단계에서 인증 정보와 공유받을 계정을 설정하면서 차량 공유 기능을 호출한다. 마지막 단계에서 공격자 단말에서 설정된 정보를 통해 인증하면 공유받은 차량의 권한을 획득할 수 있다.

## 5. 결론 및 한계점

### 5.1 결론

본 논문은 차량에 대한 물리적 접근 없이 CCA의 데이터 유출이 차량의 권한을 탈취하는 공격 벡터로 사용될 수 있음을 보인다. 취약점은 발견 이후 KISA를 통해 제조사에 보고되었고, 분석 대상 앱의 서비스 통합 및 종료 과정에서 현행 업데이트된 서비스에서는 재현되지 않음을 확인하였다.

기존에 주로 차량 내부 네트워크나 인포테인먼트 시스템 침투에 집중된 연구와 달리, 차량과 연동하는 CCA의 취약점이 차량 권한 탈취의 공격 벡터로 활용될 수 있음을 보여준다. 즉, CCA 자체의 취약점을 통해서 차량 권한이 탈취될 수 있음을 확인하였다.

공식 차량 앱은 원격 제어, 차량 공유 등 차량에 대한 긴밀한 제어 권한을 제공한다는 특성상 서드파티 앱보다 더 높은 보안 기준이 적용되어야 한다. 비 신뢰 단말 차단, 주요 기능의 강력한 인증, 안전한 데이터·키 저장, 토큰 관리 등 구현 수준의 보안 통제가 필수적이다.

### 5.2 추후 연구 방향

본 논문은 단일 CCA를 대상으로 하였기에, 모든 CCA에 차량 공유 기능에 대한 보안 취약점이 존재한다고 일반화하기는 어렵다. CCA는 OEM 마다 상이하게 개발되지만, 공통으로 유사한 기능을 제공하기 때문에 제공되는 기능을 비교 분류하고 기능별 취약한 부분을 정리하고자 한다.


## Acknowledgment

본 연구는 2024년 과학기술정보통신부 및 정보통신기획평가원의 SW중심대학사업 지원을 받아 수행되었음 (No. 2024-0-00035).

또한 이 연구는 2021년도 정부(과학기술정보통신부)의 재원으로 한국연구재단의 지원을 받아 수행된 기초연구사업임(no. 2021R1A2C2012574).

또한 정부(과학기술정보통신부)의 재원으로 정보통신기획평가원-대학ICT연구센터(ITRC)의 지원을 받아 수행된 연구임(IITP-2025-RS-2023-00259967).


## References


1) Kim, Jin, and Jinho Yoo. "Security Threat Analysis for Remote Monitoring and Control Functions of Connected Car Services." Journal of Information Processing Systems 20.2 (2024).
2) 윤지원; 황연정; 손준영. CVE 기반 자동차 보안 취약점 분석 및 위협 분류. 한국자동차공학회 춘계학술대회, 2025, 2003-2006.
3) https://www.kaspersky.com/blog/blackhat-jeep-cherokee-hack-explained/9493/
4) https://m.boannews.com/html/detail.html?idx=133436&kind=1
5) https://perfektblue.pcacybersecurity.com/
6) https://www.igloo.co.kr/security-information악성-apk을-이용한-dynamic-dex-loading-분석/